

Brian J. Scott

hello@briscosec.io · github.com/therealartifex · linkedin.com/in/brian-scott-1765b9aa

PROFESSIONAL SUMMARY

Security researcher and practitioner spanning product security research, independent threat intelligence, and offensive security consulting. Four years as a Security Research Engineer at Cisco's Advanced Security Initiatives Group (ASIG), conducting crystal-box product security evaluations across cloud, network, web application, and AI attack surfaces, including the discovery and publication of **CVE-2022-38060** (CVSS3.1: 7.8). Founder of Southwest Valley Research Group, an independently operated security research and threat intelligence practice, with work supporting direct law enforcement referrals to the FBI and ATF and contributing to active federal cases. Additional experience in contracted penetration testing and security consulting engagements for small and mid-sized organizations. Prior experience as a software engineer at HOST Engineering, including discovery of SCADA protocol vulnerabilities in industrial control systems through network traffic analysis. Holds GXPN, GCPN, CRT0, and OSCP.

EXPERIENCE

Founder and Principal Analyst

Apr. 2021–Present

Southwest Valley Research Group

- Founded and operate a structured threat intelligence operation tracking criminal actors, violent threats, and child exploitation activity across Telegram, dark web markets, and public forums; work has supported FBI and ATF referrals and contributed to active federal cases including an interstate death threats investigation.
- Built and maintain a large-scale breach intelligence corpus spanning hundreds of datasets across traditional breach dumps, stealer logs, and ransomware leak data; designed the full pipeline from collection through ingestion, parsing, normalization, and analysis using custom Python tooling and ClickHouse.
- Actively monitor criminal Telegram channels and dark web forums; track cybercriminal groups and conduct identity attribution using breach data correlation, username pivoting, public records, and OSINT tradecraft.
- Provide forensic OSINT investigations, breach data search and correlation, and subject location services to legal professionals; actively preparing for qualification as a court-recognized subject matter expert in digital intelligence and breach data analysis.
- Conduct real-time intelligence operations during high-profile domestic threat events: rapidly identify actors, map online footprints and known associates, and package findings for law enforcement and media dissemination.
- Perform operational security (OPSEC) and personal security (PERSEC) audits for individuals and organizations, identifying PII exposure and targeting risk.
- Train team members in OSINT methodology, OPSEC tradecraft, and evidentiary standards; maintain a curated TTPs resource library.

Security Research Engineer

Apr. 2022–Mar. 2026

Cisco Systems, Inc. — Advanced Security Initiatives Group (ASIG)

- Conducted crystal-box product security evaluations over four years across enterprise network, cloud, web application, and AI products; built adversary-perspective attack models prior to active testing; findings integrated into Cisco's Secure Development Lifecycle.
- Co-authored **CVE-2022-38060** (CVSS3.1: 7.8): local privilege escalation via `sudoers` PATH manipulation in OpenStack Kolla; published by Cisco Talos (TALOS-2022-1589).
- Conducted breadth-first transport security review of a distributed network security platform; identified unauthenticated RPC channels confirmed via passive capture of plaintext payloads containing credentials and policy data.

- Traced control-plane data paths from RPC deserialization through to hardware dataplane programming with no input validation at any layer; demonstrated unauthenticated injection of arbitrary firewall rules into hardware-accelerated enforcement.
- Identified path traversal via unsanitized protobuf field flowing to filesystem write operations; identified TLS certificate verification disabled on a management channel transmitting credentials in plaintext, enabling credential capture via transient MITM with no container escape required.
- Assessed credential storage on a containerized Kubernetes platform; identified service account tokens accessible via unauthenticated local socket and duplicated to world-readable paths; delivered remediation recommendations covering secret storage, permission hardening, and RBAC scope reduction.
- Identified complete JWT signature verification bypass in a web application via static analysis; all protected endpoints bypassable via forged tokens enabling authentication bypass and arbitrary privilege escalation.
- Traced cleartext password lifecycle through a two-stage TPM decryption architecture using Frida to hook Windows cryptographic APIs during live authentication; identified credential exposure window in process memory and delivered remediation recommendations for explicit memory sanitization.
- Developed PoC exploits in Go, C++, and PowerShell; evaluated LLM product via prompt injection, bypassing guardrails and demonstrating unauthorized data access; briefed findings to product teams and division-wide readout sessions.

Penetration Tester

2021

Gray Station CPAs PC, Gray, TN — Contract Engagement

- Conducted physical and network penetration testing, social engineering, and OSINT investigation for a defined-scope assessment; delivered formal report with prioritized remediation guidance and staff security training recommendations.

Software Engineer

Jun. 2018–Oct. 2021

HOST Engineering, Jonesborough, TN

- Discovered broadcast amplification and packet replay vulnerabilities in a proprietary industrial SCADA protocol (Host Automation Protocol) through Wireshark traffic analysis; reported findings leading to remediation in deployed water treatment and energy infrastructure systems.
- Contributed to PLC programming software development in MFC and C++ for industrial automation products.

SELECTED PROJECTS

- **CVE-2022-38060 — OpenStack Kolla** (CVSS 3.1: 7.8, High): Co-discovered local privilege escalation via `sudoers` PATH manipulation enabling arbitrary command execution as root from within a containerized OpenStack deployment. Published by Cisco Talos, Dec. 2022. TALOS-2022-1589
- **fff — Fast Find in Files**: SIMD/AVX-optimized, multi-threaded file search tool written in C++, purpose-built for stealer log analysis; distributes file chunks equally across all cores; demonstrably faster than `grep` at all tested file sizes. github.com/therealartifex/fff
- **Threat Intelligence and Detection Research Platform** (in progress): Designing and deploying a multi-tier security research environment spanning network segmentation, PKI, SSO with hardware-backed MFA, 802.1X enterprise authentication, and telemetry-based detection with behavioral analysis. In-progress integration of a local retrieval-augmented generation pipeline for analyst-facing intelligence synthesis.
- **Hashcat Module — Ruby on Rails RESTful Auth Hashes**: Developed native hashcat cracking module eliminating manual preprocessing for this hash type; merged into the official project. PR #2914

EDUCATION

Bachelor of Science, Computer Science

2018

Network Security Concentration · Minor in Applied Sciences

LeTourneau University, Longview, TX

CERTIFICATIONS AND TRAINING

- GIAC Exploit Researcher and Advanced Penetration Tester (GXPN) — 2024
- GIAC Cloud Penetration Tester (GCPN) — 2022, exp. Nov. 2026
- Offensive Security Certified Professional (OSCP) — 2022
- Zero-Point Security Certified Red Team Operator (CRTO) — 2021
- Sektor7 Institute: Red Team Operations — Malware Development, EDR Evasion, and Windows Privilege Escalation

TECHNICAL SKILLS

Offensive Security: Crystal-box and black-box product security evaluation; web application testing (Burp Suite, Nuclei); cloud security assessment (Pacu, AWS); network penetration testing; adversary emulation (Cobalt Strike); dynamic instrumentation (Frida); malware development; EDR evasion; exploit research and PoC development.

Threat Intelligence and OSINT: Breach data analysis and correlation; criminal forum and Telegram channel monitoring and infiltration; threat actor profiling and attribution; digital footprint analysis; subject location (skip tracing); forensic OSINT; public records research; Maltego; R.

Detection and Analytics: ClickHouse, Elasticsearch, Kibana, Splunk, Zeek, Suricata, Grafana, Fluent-bit, XWays Forensics.

Security Architecture and Infrastructure: PKI, TLS/mTLS, JWT, SSH CA (Ed25519), MFA/WebAuthn, 802.1X/EAP, Keycloak/OIDC, FreeRADIUS, Active Directory, VLAN segmentation, firewall policy design.

AI Security and AI-Augmented Workflow: LLM prompt injection; guardrail bypass; agentic pipeline attack surface assessment; AI-assisted static code analysis (Windsurf, Claude) integrated into vulnerability research workflows; retrieval-augmented generation (RAG) pipeline design with Qdrant for analyst-facing intelligence synthesis.

Static Analysis and Code Review: Semgrep, Trufflehog, manual source code review.

Programming: C/C++ (Windows API, SIMD/AVX, in-memory shellcode development), Python, PowerShell, C#, Go, SQL.

Infrastructure: Proxmox VE, Linux (Debian/Ubuntu), FreeBSD, AWS, Kubernetes, Active Directory, Windows Server.